

COMPANY INTERNAL POLICIES

Sample Enterprise Policy Handbook

Document ID: CIP-2026-002. Version: 1.0. Effective date: 01 August 2026. Classification: Internal Use. Policy owner: Corporate Governance.

This is a synthetic text-only company policy document created for learning and testing document ingestion pipelines. It intentionally contains ordinary paragraphs, headings, lists, definitions, procedures, and cross-references. It contains no tables, diagrams, charts, photographs, or other graphical elements.

1. Information Security Policy

Purpose

The company protects confidential, personal, financial, operational, and proprietary information through administrative, technical, and physical safeguards. Every employee is responsible for protecting information that they access as part of their role.

Scope

This policy applies to employees, contractors, interns, temporary workers, consultants, and approved third parties who access company information, applications, devices, networks, or facilities.

Security Requirements

- Employees must use company-managed accounts when accessing business systems.
- Credentials must never be shared with another person.
- Multi-factor authentication is required for systems designated as critical or externally accessible.
- Sensitive information must be stored only in approved company repositories.
- Company devices must use supported operating systems, endpoint protection, disk encryption, and automatic security updates.
- Employees must report suspected credential compromise, accidental disclosure, malware, or lost company devices to the Security Operations team.
- Employees must not disable security controls without written authorization from the Security function.

Access Reviews

Managers and system owners must review sensitive and privileged access periodically. Access must be removed or modified when an employee changes role, transfers to another team, or leaves the company.

2. Acceptable Use of Technology

Purpose

Company technology is provided primarily for legitimate business activities. Limited personal use is permitted when it does not interfere with work, violate company policy, create material risk, or consume unreasonable company resources.

Prohibited Activities

- Attempting to bypass authentication, endpoint protection, network controls, or other security mechanisms.
- Accessing systems or data without authorization.
- Installing unapproved software or browser extensions on managed devices.
- Using company systems to distribute malicious software.
- Using company resources for unlawful activities.
- Uploading confidential or restricted company information to unapproved external AI systems.
- Using company systems for harassment, threats, discrimination, or other prohibited conduct.

Monitoring

The company may log and review activity on company systems to protect security, investigate incidents, maintain system reliability, and satisfy legitimate compliance requirements, subject to applicable law and internal privacy

requirements.

3. Data Classification and Handling

Classification

- Public information is approved for public distribution.
- Internal information is routine business information that is not intended for public release.
- Confidential information could cause business, legal, financial, or reputational harm if improperly disclosed.
- Restricted information is highly sensitive information requiring the strongest access and handling controls.

Handling Requirements

- Public information may be shared externally when approved for publication.
- Internal information should remain within approved company collaboration platforms.
- Confidential information must be accessed only by authorized personnel with a legitimate business need.
- Restricted information requires explicit authorization and enhanced safeguards.
- Employees must verify recipients before sending confidential or restricted information.
- Sensitive documents must not be copied to personal storage accounts.

Retention

Business records must be retained according to the applicable retention schedule. Employees must not delete records that are subject to a legal hold, investigation, audit, or regulatory requirement.

4. Remote and Hybrid Work Policy

Eligibility

Remote and hybrid arrangements depend on role requirements, business needs, security considerations, local employment requirements, and manager approval.

Security Expectations

- Workers must use approved company devices.
- Company devices must be protected from unauthorized physical access.
- Confidential conversations should not take place where unauthorized people can overhear them.
- Printed confidential material must be secured and disposed of using approved methods.
- Employees must lock their screen whenever leaving a device unattended.
- Company equipment must not be loaned to household members or other unauthorized persons.

Travel

Employees traveling internationally with company equipment must follow Security guidance. Certain destinations or circumstances may require additional controls, loaner equipment, or restrictions on accessing sensitive systems.

5. Password and Authentication Policy

Password Requirements

- Passwords must be unique to the company account.

- Passwords must not be reused across unrelated services.
- Passwords and authentication secrets must never be sent through email, chat, tickets, or ordinary documents.
- Approved password managers must be used where provided.
- Employees must not approve unexpected multi-factor authentication prompts.
- Repeated unexpected authentication prompts must be reported as a potential account takeover attempt.

Privileged Access

Administrative access must be protected with enhanced controls. Privileged credentials should be separate from ordinary user credentials where technically feasible. Privileged activity must be logged and reviewed according to system risk.

6. Employee Conduct and Workplace Standards

Expected Conduct

Employees are expected to communicate professionally, respect colleagues and customers, protect company property, follow applicable laws, and comply with company policies.

Examples of Misconduct

- Harassment, intimidation, discrimination, or retaliation.
- Fraud, theft, falsification of records, or deliberate misuse of company assets.
- Unauthorized disclosure of confidential company information.
- Undisclosed conflicts of interest that affect business decisions.
- Interference with an internal investigation.
- Deliberate destruction or alteration of evidence relevant to an investigation.

Reporting

Concerns may be raised with a manager, People Operations, Compliance, Legal, or another approved reporting channel. Retaliation against a person who raises a concern in good faith is prohibited.

7. Conflict of Interest Policy

Purpose

Employees must avoid situations in which personal interests materially conflict, or appear to conflict, with their company responsibilities.

Examples

- Having a financial interest in a supplier or competitor that could influence business judgment.
- Participating in hiring or procurement decisions involving a close personal relationship.
- Accepting outside employment that interferes with company responsibilities.
- Using company information to benefit a personal business.
- Accepting gifts or benefits that could influence a business decision.

Disclosure

Potential conflicts must be disclosed to the employee's manager and the appropriate Compliance or People function. Mitigation may include recusal, reassignment, additional approvals, or other controls.

8. Procurement and Vendor Management

Purchasing

Employees must use approved procurement processes for company purchases. Business owners are responsible for defining requirements, confirming budget availability, and using authorized purchasing channels.

Vendor Risk

- Vendors handling sensitive company information may require security and privacy review.
- Contracts should contain appropriate confidentiality, data protection, service, and termination provisions.
- Material vendors should be periodically reviewed for performance and risk.
- Employees must not commit the company to contractual terms without appropriate authority.

Emergency Procurement

Urgent purchases may use an emergency procurement procedure when delay could create material operational, security, or safety risk. The transaction must be documented and regularized afterward.

9. Expense and Travel Policy

Eligible Expenses

Reasonable business expenses incurred for approved company activities may be reimbursed when supported by required documentation.

Expense Rules

- Expense claims should normally be submitted within thirty calendar days.
- Required receipts must be retained and submitted according to Finance procedures.
- Personal expenses must not be submitted for reimbursement.
- Employees must disclose refunds or credits related to company expenses.
- Expenses must accurately describe the business purpose.

Travel

Travel should normally be booked through approved channels. Employees should select reasonable transportation and accommodation options consistent with business requirements and applicable company limits.

10. Business Continuity and Disaster Recovery

Objective

The company maintains continuity capabilities to reduce the impact of outages, cyber incidents, natural disasters, supplier failures, and other disruptive events.

Planning Requirements

- Business units must identify critical processes and dependencies.
- Critical services must have designated owners.

- Recovery priorities must be documented.
- Critical backups must be protected from unauthorized modification.
- Recovery procedures must be tested periodically according to risk.
- Significant exercises and incidents should result in documented corrective actions.

Recovery

Recovery activities should restore essential services in a controlled manner while preserving security and operational integrity. Recovery decisions must consider business impact, customer impact, regulatory obligations, and available resources.

11. Incident Response Policy

Incident Types

Security incidents may include suspected account compromise, malware, unauthorized access, data exposure, lost devices, suspicious communications, service compromise, or misuse of company resources.

Response Process

- Identify and report the suspected incident.
- Contain affected accounts, devices, systems, or data when instructed.
- Preserve relevant evidence.
- Avoid unnecessary changes to affected systems.
- Security personnel assess scope and severity.
- Appropriate stakeholders are notified according to the incident response process.
- Recovery activities restore normal operations.
- Significant incidents are followed by lessons-learned activities.

Critical Incidents

Critical incidents are events with major impact on sensitive information, critical services, customers, or business operations. Critical incidents may require executive escalation and specialized response procedures.

12. Privacy and Personal Data Policy

Principles

Personal data must be collected, used, retained, and disclosed for legitimate purposes and handled according to applicable privacy requirements.

Requirements

- Collect only information reasonably necessary for an approved business purpose.
- Limit access to authorized personnel.
- Use approved systems for storing and processing personal data.
- Do not share personal data with unauthorized recipients.
- Respond to privacy requests through designated privacy processes.
- Report suspected personal-data incidents to the Privacy or Security function.

Accountability

Teams that design or operate processes involving personal data are responsible for understanding applicable requirements and engaging Privacy or Legal when required.

13. Records Management Policy

Record Types

Company records may include contracts, financial records, personnel records, customer records, security logs, audit evidence, operational documentation, and approved communications.

Retention

Retention periods depend on record type, legal requirements, contractual commitments, operational needs, and approved retention schedules.

Legal Hold

When a legal hold is issued, affected records must be preserved until the hold is formally released. Employees must follow instructions from Legal or the designated records owner.

Deletion

Records must be disposed of securely when their approved retention period ends and no preservation requirement applies.

14. Artificial Intelligence and Generative AI Policy

Approved Use

Employees may use approved AI systems for permitted business purposes. Data classification requirements apply to prompts, uploaded documents, generated content, and outputs.

Restricted Activities

- Do not submit restricted information to an AI service unless the service and use case have been explicitly approved.
- Do not assume AI-generated information is accurate or complete.
- Human review is required for consequential business decisions.
- AI-generated code must undergo appropriate engineering and security review before production use.
- Employees remain responsible for protecting confidential information when using AI tools.

Output Review

AI-generated content must be reviewed for factual accuracy, confidentiality, intellectual-property considerations, security concerns, and suitability for the intended audience.

15. Software Development and Change Management

Development Standards

Engineering teams must follow approved source-control, code-review, testing, dependency-management, and deployment practices.

Change Controls

- Material production changes require peer review and appropriate testing.
- Emergency changes may use an expedited process but must be documented afterward.
- Production credentials and secrets must not be committed to source repositories.
- Changes affecting critical systems should include rollback or recovery considerations.
- Changes that introduce material security risk require appropriate Security review.

Vulnerability Management

Known vulnerabilities must be prioritized according to severity, exploitability, exposure, and business impact. Risk exceptions must be documented and assigned to an accountable owner.

16. Physical Security and Workplace Access

Access Badges

Badges must not be shared. Lost or stolen badges must be reported promptly.

Visitors

Visitors must follow site-specific registration and escort requirements. Visitors must not receive unsupervised access to restricted areas unless explicitly authorized.

Clean Desk

Confidential and restricted materials should not be left unattended in shared or public spaces. Sensitive documents should be securely stored or disposed of when no longer required.

17. Business Communications and External Statements

External Communications

Only authorized representatives may make official public statements on behalf of the company.

Social Media

Employees may express personal opinions but must not imply that they are speaking for the company unless authorized. Confidential information must never be disclosed.

Customer Communications

Customer-facing teams must use approved communication procedures for sensitive complaints, security incidents, legal matters, or regulated requests.

18. Policy Exceptions

Exception Process

Exceptions must document the policy requirement, business justification, risk assessment, compensating controls, requested duration, and accountable owner.

Approval

Approval requirements depend on the policy and risk level. Temporary exceptions should include an expiration date.

Review

Expired exceptions must be closed, renewed through the formal process, or converted into a permanent process or policy change.

19. Training and Awareness

Mandatory Training

Employees must complete required security, privacy, compliance, workplace conduct, and role-specific training within the assigned timeframe.

Non-Completion

Failure to complete mandatory training may result in reminders, manager escalation, restricted access, or other action consistent with company procedures.

Awareness

Periodic awareness activities may cover phishing, password safety, data handling, incident reporting, privacy, and emerging technology risks.

20. Policy Governance

Policy Ownership

Each policy has a designated owner responsible for maintaining its content, coordinating reviews, and ensuring that significant changes are communicated.

Review Cycle

Policies should be reviewed at least annually and sooner when laws, technology, business processes, material risks, or organizational structures change.

Version Control

Superseded versions must be retained according to records-management requirements. The current approved version must be clearly identifiable.

Employee Responsibility

Employees are responsible for reading and following policies applicable to their role and asking the appropriate function when requirements are unclear.

Appendix A — Operational Procedures

A.1 Suspected Phishing Procedure

When an employee receives a suspicious message, they should avoid clicking links or opening unexpected attachments, verify the sender through an independent channel when appropriate, and report the message using the approved security-reporting process. If credentials were entered into a suspicious site, the employee must immediately report the event and follow Security instructions for account protection. Employees should not delete evidence if Security requests that the original message be preserved.

A.2 Lost Device Procedure

A lost or stolen company device must be reported promptly. The employee should provide the device type, approximate time of loss, last known location, and any relevant circumstances. Security or IT may remotely lock, disable, or wipe the device when appropriate. The incident may require credential resets or additional investigation depending on the information accessible from the device.

A.3 Employee Offboarding Procedure

When an employee leaves the company, the responsible teams coordinate account deactivation, equipment return, access removal, transfer of business records, and other applicable controls. Managers must identify critical work that requires transition. Employees must not retain company information on personal devices or accounts after separation.

A.4 New Vendor Onboarding Procedure

A business owner initiates vendor onboarding by describing the service, business purpose, data involved, expected access, and contractual requirements. Procurement coordinates commercial review. Security and Privacy may conduct risk assessments based on the service and data classification. The vendor may not receive production access until required approvals are complete.

A.5 Security Incident Escalation Procedure

Employees who suspect a security incident should report the event rather than attempting to conduct an independent investigation. Security personnel determine severity, containment actions, required stakeholders, evidence-handling requirements, and recovery steps. Communications with customers, regulators, or external parties must follow the incident communications process.

A.6 Data Access Request Procedure

Requests for access to sensitive data must identify the requester, business purpose, requested scope, and duration where applicable. The designated owner validates the need and authorization. Access should be limited to the minimum necessary scope. Temporary access should expire automatically when technically feasible.

A.7 Policy Exception Procedure

A policy exception begins with a documented request describing the requirement that cannot currently be met and why. The requester identifies risks and proposed compensating controls. The policy owner and required risk or compliance stakeholders review the request. Approved exceptions are tracked until they expire or are formally closed.

A.8 AI Tool Approval Procedure

Before adopting an external AI service for business use, the requesting team should identify the intended use case, information types, users, integrations, retention behavior, security controls, and expected outputs. The relevant technology, security, privacy, legal, and procurement reviews are completed according to risk. Approval must be recorded before sensitive information is processed.

Appendix B — Glossary

Access Review

A periodic examination of user and system permissions to confirm that access remains appropriate.

Business Owner

The person accountable for a business process, service, system, vendor relationship, or data use.

Confidential Information

Information whose unauthorized disclosure could reasonably cause material harm.

Data Owner

The person or function responsible for defining appropriate access and handling requirements for a data set.

Exception

A formally approved deviation from a documented policy requirement.

Incident

An event that may affect security, privacy, availability, integrity, or authorized use.

Internal Information

Business information intended for use within the company and not approved for public release.

Legal Hold

A formal instruction requiring potentially relevant records to be preserved.

Need-to-Know

A principle under which access is limited to information required to perform an authorized responsibility.

Privileged Access

Elevated access that permits administrative or security-sensitive actions.

Restricted Information

Highly sensitive information requiring enhanced authorization and safeguards.

Risk Owner

The person accountable for accepting, mitigating, transferring, or avoiding a defined risk.

Sensitive Information

Information requiring additional protection because unauthorized disclosure, modification, or loss could cause harm.

System Owner

The person or function accountable for a system's operation, access controls, and lifecycle.

Third Party

An external organization or individual that provides services or otherwise interacts with company systems or information.

End of document. All content is fictional and intended solely for document-ingestion learning, testing, and demonstration.